ONE-PAGE BRIEF

Post-quantum cryptography review: scroll @ 3046bbd18a6a

Client: Scroll — public repository (passive review) · Source: github.com/scroll-tech/scroll, commit `3046bbd18a6a` · Reviewed: 2026-11-06 13:55 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY

Level 4 of 4

post-quantum by default in the critical paths

FINDINGS

8 Critical **17** High **24** Medium **43** Low **80** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Keep the inventory current and review new code paths before release.

WHAT MATTERS MOST

Critical QSI-2026-18907	**github.com/gin-contrib/cors v1.5.0 is affected by GHSA-869c-j7wc-8jqv (CVE-2019-25211, GO-2024-2955)** What to do: Upgrade to a fixed version (1.6.0).
Critical QSI-2026-18927	**golang.org/x/crypto v0.32.0 is affected by GHSA-5cgq-3rg8-m6cv (CVE-2026-42508)** What to do: Upgrade to a fixed version (0.52.0).
Critical QSI-2026-18929	**golang.org/x/crypto v0.32.0 is affected by GHSA-89gr-r52h-f8rx (CVE-2026-39831)** What to do: Upgrade to a fixed version (0.52.0).
Critical QSI-2026-18931	**golang.org/x/crypto v0.32.0 is affected by GHSA-f5wc-c3c7-36mc (CVE-2026-39832)** What to do: Upgrade to a fixed version (0.52.0).

88 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium transaction and message signing	ECDSA	Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum...
Medium authentication and identity (certificates, tokens, device attestation)	ECDSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Medium role not determined	ECDSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)...

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 114; unlikely to apply to this build: 52 (a Cargo feature that is off, affected functions not named in the code, or a platform that is not built); to review: 62.

Static review of source code and manifests; files analysed: 387. No requests were sent to the owner's systems.

Full report, content SHA-256: `2342544e2f15be7ff1cd0fe90d6248110e49102a5b68bcaa0d27a0fb55b3c431`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.